

Nmap Enumeration Lab (v2) — Metasploitable2

Tool utilizzato:

Nmap Target: Metasploitable2 (VM deliberatamente vulnerabile, ambiente isolato/locale)

Ambiente: Kali Linux + Metasploitable2, entrambe VM UTM su Apple Silicon

Nota etica/metodologica: Metasploitable2 è una macchina virtuale progettata appositamente per la pratica di sicurezza offensiva/difensiva, distribuita gratuitamente proprio a questo scopo. Il lab qui descritto si è fermato alla fase di enumeration (raccolta informazioni passiva/attiva non distruttiva) — nessun exploit è stato eseguito.

Obiettivo:

Ripetere la stessa metodologia di enumerazione già applicata sulla rete domestica (vedi lab precedente), stavolta su un target con superficie d'attacco intenzionalmente ampia, per esercitarsi nell'interpretazione di un numero realistico di servizi/vulnerabilità in un unico host.

Metodologia:

Stesso flusso a imbuto della versione precedente: discovery → port/service scan → script NSE, con enfasi qui sull'interpretazione critica di ogni servizio trovato.

1. Host discovery

```
sudo nmap -sn 192.168.1.0/24
```

Identificati 11 host attivi sulla rete, incluso il target IPAD.station (192.168.1.29) — hostname fuorviante ereditato da una precedente assegnazione DHCP (lezione: i nomi host da discovery non sono sempre affidabili, vanno verificati con altri mezzi, ad es. confronto diretto con ifconfig sulla macchina target).

2. Port scan con version detection

```
sudo nmap -sV 192.168.1.29
```

Risultato: 23 porte aperte su 999 scansionate (contro l'1 sola del lab precedente sulla rete domestica) — conferma della natura intenzionalmente esposta del target.

3. Scansione combinata con script NSE

```
sudo nmap -sV -sC 192.168.1.29
```

Findings principali

Porta 21 - vsftpd 2.3.4

Login FTP anonimo consentito (ftp-anon: Anonymous FTP login allowed). Questa versione specifica è storicamente nota per una backdoor inserita da un compromesso alla supply chain del progetto nel 2011 (non una vulnerabilità "scoperta", un attacco al codice sorgente ufficiale).

Porta 22 – OpenSSH 4.7p1

Versione datata (2007 circa), utile come riferimento per verificare se le versioni installate sono aggiornate rispetto ai CVE noti.

Porta 23 – Linux telnetd

Telnet trasmette credenziali in chiaro — protocollo considerato insicuro da tempo, sostituito da SSH in ambienti moderni.

Porta 25 – Postfix smtpd

Script NSE ha rilevato supporto SSLv2 (protocollo crittografico obsoleto, con cifrari deboli come SSL2 RC4_128_EXPORT40) e un certificato scaduto (validità 2010, ormai storicamente non valido).

Porta 111 – rpcbind

rpcinfo ha enumerato tutti i servizi RPC registrati (NFS, mountd, status, ecc.) — utile mappa di servizi correlati.

Porte 139/445 – Samba smbd 3.X

Script smb-security-mode ha rilevato message signing disabilitato (disabled (dangerous, but default)) — espone a rischio di attacchi man-in-the-middle su SMB.

Porte 512/513/514 – exec/login/tcpwrapped

Servizi storicamente insicuri (r-services), autenticazione debole per design.

Porta 1524 – bindshell

Nmap identifica direttamente il servizio come "Metasploitable root shell" — una shell di root già in ascolto senza autenticazione, simula uno scenario di sistema già compromesso in precedenza.

Porta 3306 – MySQL 5.0.51a

Script mysql-info ha estratto dettagli del protocollo, incluso il salt di autenticazione — informazione che in un contesto reale andrebbe protetta da esposizione non necessaria.

Porta 5432 – PostgreSQL 8.3

Stesso pattern di SSLv2/certificato scaduto osservato su SMTP.

Porta 5900 – VNC (protocollo 3.3)

Versione di protocollo molto datata, con schema di autenticazione debole per gli standard moderni.

Porta 6667 – UnrealIRCd

Servizio IRC — storicamente questa versione è stata bersaglio di un backdoor noto in una release compromessa (2010), simile al caso vsftpd.

Porta 8009 – AJP13 (Apache Jserv)

Protocollo storicamente vulnerabile a "Ghostcat" (CVE-2020-1938) in versioni Tomcat non aggiornate.

Porta 8180 – Apache Tomcat/Coyote 1.1

Secondo web server, spesso associato a credenziali di default sul pannello manager in ambienti di test.

Script host-level aggiuntivi rilevanti:

- clock-skew : disallineamento orario significativo rilevato tra host — in un contesto reale, un orologio di sistema errato può compromettere l'affidabilità dei timestamp nei log durante un'investigazione
- smb-os-discovery : ha rivelato hostname interno (metasploitable), dominio (localdomain) e nome NetBIOS — utile per fingerprinting del sistema senza credenziali

Conclusioni:

Il confronto diretto con il lab precedente (rete domestica, 1 host/1 porta) evidenzia bene la differenza tra un ambiente con buona postura di sicurezza (superficie minima, nessuna versione esposta) e un ambiente deliberatamente vulnerabile (23 porte, versioni datate, servizi con vulnerabilità storiche note, configurazioni deboli per design). Il valore didattico principale non è stato exploitare i servizi, ma allenarsi a leggere un output Nmap denso e a dare priorità — distinguendo, tra 20+ servizi, quali meritano approfondimento immediato (vsftpd, bindshell, SMB signing) da quelli meno critici in un contesto di triage iniziale.

Cosa ho imparato:

- Interpretazione di un output NSE su larga scala, con più script attivi contemporaneamente su porte diverse
- Riconoscimento di indicatori di rischio da nome/versione servizio prima ancora di consultare database CVE esterni (vsftpd 2.3.4, UnrealIRCd versione specifica, r- services)
- Lettura di script di sicurezza specifici: ftp-anon, smb-security-mode, mysql-info, ssl-cert / sslv2
- Importanza di non fidarsi ciecamente dei nomi host risolti da Nmap
- Distinzione tra fase di enumeration (informativa, quello che abbiamo fatto) e fase di exploitation (attiva, fuori dallo scope di questo lab)

Lab correlato: Nmap Enumeration Lab v1 — rete domestica, usato come termine di paragone.